

MEDISYNC SOLUTIONS

ACCESS CONTROL POLICY

CONFIDENTIAL | INTERNAL USE ONLY

Document ID:	POL-003
Version:	1.0
Owner:	CISO — Isha Gupta
Approved by:	CEO — Marcus Chen
Effective Date:	September 1, 2026
Review Date:	September 1, 2027
ISO 27001 Ref:	A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.3, A.8.5
HIPAA Ref:	§164.308(a)(3)(ii), §164.308(a)(4), §164.312(a)(1), §164.312(a)(2)
NIST CSF Ref:	PR.AA-01 through PR.AA-06

1. Purpose & Scope

This policy governs logical and physical access to all MediSync systems, applications, and data. It applies to all 78 employees, contractors, and third parties; all systems including the Care Platform, FHIR API, AWS environment, Okta, Splunk Cloud, and GitHub Enterprise; and all data classifications — with particular emphasis on Critical-tier PHI across approximately 2.3 million patient records.

2. Access Provisioning

All access must be formally requested, manager-approved, and provisioned through Okta before use. PHI system access (Care Platform production, AWS RDS, S3 PHI buckets) additionally requires written CISO approval. Provisioning is completed within 3 business days of full approval. All access is role-based — no individual receives permissions beyond what their specific function requires (least privilege). Shared accounts are prohibited. Service accounts require CISO approval, a named human owner, and are registered in the service account inventory maintained by the IT Manager.

3. Least Privilege & Access Roles

Access is granted at the minimum level necessary. Defined Okta RBAC roles include:

- Care Coordinator: read/write access to assigned patient care team records only
- Developer: read/write in development/staging; read-only production logs; no direct PHI database access
- Security Engineer: read access to all logs and security configs; no patient clinical data access
- IT Support: endpoint management only; PHI system access requires time-limited CISO approval
- Privileged (CISO, IT Manager): AWS IAM admin, Okta admin, GitHub org owner — separate from standard accounts; all sessions logged in Splunk Cloud

4. Multi-Factor Authentication

MFA via Okta is mandatory for all system access and cannot be bypassed. Acceptable methods in order of preference: (1) FIDO2 hardware key — required for AWS root and Okta admin accounts; (2) Okta Verify push with biometric — standard for all other access; (3) TOTP authenticator app — permitted where Okta Verify is unsupported. SMS OTP is prohibited for PHI systems. MFA enrollment must be completed within 24 hours of account creation; unenrolled accounts are auto-disabled by Okta policy.

5. Remote Access

All remote access to internal systems and the AWS production environment requires MediSync VPN with Okta MFA. Split tunneling is prohibited. Access from personal devices is prohibited — only company-issued MDM-enrolled laptops with full disk encryption are permitted. VPN sessions timeout after 60 minutes of inactivity.

6. Password Requirements (NIST SP 800-63B)

- Minimum length: 12 characters

- No mandatory periodic rotation — passwords changed only upon suspected or confirmed compromise
- Last 12 passwords prohibited for reuse
- Common passwords and contextual guesses (e.g., "MediSync2026") prohibited via Okta policy
- Account lockout after 10 consecutive failed attempts; unlocked by IT Manager following identity verification
- MediSync 1Password license provided to all employees; personal password managers for MediSync credentials prohibited

7. Access Reviews

Quarterly access reviews are conducted for all PHI-containing systems. The GRC Analyst distributes certification reports to department managers, who must certify or revoke access for each direct report within 10 business days. Uncertified accounts are automatically suspended. Annual reviews apply to all other systems. Review documentation is retained for 6 years (HIPAA). The CISO separately reviews all privileged accounts monthly.

8. Access Termination

Upon employee termination, resignation, or role change, HR notifies the IT Manager and CISO within 2 hours of the effective date. The IT Manager disables the Okta account the same business day, simultaneously revoking all SSO-connected system access. Company devices must be returned within 5 business days; MDM remote wipe is initiated if devices are not returned. The GRC Analyst verifies complete access removal at the next quarterly review.

9. Enforcement, Exceptions & Review

Violations are subject to disciplinary action up to termination; PHI-related violations may trigger HIPAA breach assessment. Exceptions require written CISO approval, documented business justification, compensating controls, and a maximum 90-day duration. This policy is reviewed annually and upon significant incidents, infrastructure changes, or regulatory updates.

Next review: September 1, 2027 | Document owner: CISO, MediSync Solutions | POL-003 v1.0